

# Incident-Response Playbook

Operational Manual for On-Call Engineers,  
Support, Security-Engineers & Compliance Teams

---

## SCOPE

This playbook covers three critical incident scenarios: High-Risk Events (RED-Spike/Fraud-Wave), Risk-Engine Down/Degraded, and Mitigation-Queue Overload. Each scenario includes detection criteria, immediate actions (0-5 min), triage (5-15 min), mitigation (15-60 min), recovery procedures, post-incident review, and owner assignments.

# Table of Contents

| Section                                                 | Page |
|---------------------------------------------------------|------|
| 1. Overview & Purpose                                   | 3    |
| 2. Scenario 1: High-Risk Event (RED-Spike / Fraud-Wave) | 4    |
| 3. Scenario 2: Risk-Engine Down / Degraded              | 7    |
| 4. Scenario 3: Mitigation-Queue Overload                | 10   |
| 5. Owner Matrix & Escalation Paths                      | 13   |
| 6. Quick Reference Cards                                | 14   |

# 1. Overview & Purpose

This Incident-Response Playbook provides structured, actionable procedures for handling critical security incidents within the CargoBit Security-Gateway infrastructure. It is designed for immediate operational use by On-Call Engineers, Support Teams, Security-Engineers, and Compliance Officers.

Key Objectives:

- Minimize Mean Time to Detect (MTTD) and Mean Time to Resolve (MTTR)
- Provide clear decision trees for each incident type
- Define ownership and escalation paths
- Ensure audit trail integrity during incident response
- Maintain service availability while protecting against fraud

Severity Levels:

| Level         | Definition                                        | Response Time | Example                               |
|---------------|---------------------------------------------------|---------------|---------------------------------------|
| P1 - Critical | Service down or security breach in progress       | < 15 minutes  | Risk-Engine complete outage           |
| P2 - High     | Significant degradation or fraud pattern detected | < 30 minutes  | Fraud-wave spike, queue overload      |
| P3 - Medium   | Partial degradation, single component affected    | < 2 hours     | Increased latency, minor alert spikes |
| P4 - Low      | Minor issue, workaround available                 | < 24 hours    | Single rule misfire, cosmetic issues  |

Table 1: Incident Severity Classification

## 2. Scenario 1: High-Risk Event (RED-Spike / Fraud-Wave)

### 2.1 Detection

Alert Triggers:

- Grafana Alert: `rate(risk_level_total{level="red"}[5m]) > 50`
- Gateway: Rising block rate in Security-Gateway metrics
- Notification-Service: High volume of High-Risk alerts being dispatched
- Support: Unusual spike in support tickets related to blocked transactions

### 2.2 Immediate Actions (0-5 Minutes)

On-Call Engineer Responsibilities:

| Step | Action                                                                          | Expected Outcome                                           |
|------|---------------------------------------------------------------------------------|------------------------------------------------------------|
| 1    | Confirm alert in Alertmanager                                                   | Alert is valid, not a false positive                       |
| 2    | Check Risk Dashboard: Level Distribution, Triggered Rules (Top 10), Geo-Heatmap | Understand scope and pattern of spike                      |
| 3    | Activate "Fraud-Mode" in Gateway if available                                   | Stricter thresholds, optional auto-block for certain rules |
| 4    | Notify Security-Engineer and Compliance                                         | Key stakeholders aware, ready for escalation               |

Table 2: Immediate Actions Checklist

### 2.3 Triage (5-15 Minutes)

Investigation Steps:

- Determine if spike is regional or global (check geo-distribution)
- Identify dominant rules triggering: `tx_high_amount`, `user_new_iban`, `geo_mismatch`

- Check for specific patterns: same client, company, IP-range, or user cohort
- Verify Risk-Engine health: latency, error rate, response codes
- Confirm Audit-Events are being written correctly

#### Decision Tree:

| Finding                                        | Classification | Next Step                                                    |
|------------------------------------------------|----------------|--------------------------------------------------------------|
| Clear fraud pattern identified                 | Fraud-Wave     | Proceed to Mitigation Section 2.4                            |
| Rules firing incorrectly on legitimate traffic | False Positive | Deactivate problematic rule, proceed to Risk-Engine Playbook |
| Risk-Engine returning errors/timeouts          | System Issue   | Switch to Scenario 2 Playbook                                |

Table 3: Triage Decision Matrix

## 2.4 Mitigation (15-60 Minutes)

### Option A: Confirmed Fraud-Wave

- Block affected entities: Add user IDs, company IDs, or IP ranges to blocklist
- Activate "Strict Mode": Yellow → Red, Delay → Block for affected transaction types
- Temporary Geo-Block: If spike is region-specific, implement geo-fencing
- Notification cascade: Inform Compliance and Security via Slack/Email/SMS
- Documentation: Log all actions with timestamps in incident ticket

### Option B: Rule Misconfiguration

- Deactivate problematic rule: Set rule.active = false in Risk-Rules configuration
- Apply override: For affected entities, manually adjust risk level if justified
- Prepare hotfix: If bug identified, prepare Risk-Engine patch for deployment
- Monitor: Watch for rule re-enable confirmation in deployment logs

## 2.5 Recovery

| Indicator               | Target                     | Verification Method          |
|-------------------------|----------------------------|------------------------------|
| Risk-Level Distribution | Normalized to baseline     | Grafana dashboard comparison |
| Block Rate              | < 5% of total transactions | Gateway metrics              |
| Strict Mode             | Disabled                   | Configuration check          |
| Audit-Trail Integrity   | All events written         | Audit service health check   |
| Mitigation Queue        | Processed, lag < 2s        | Queue metrics                |

Table 4: Recovery Validation Checklist

## 2.6 Post-Incident (24-72 Hours)

- Root Cause Analysis (RCA): Document timeline, root cause, and contributing factors
- Fraud Pattern Integration: Add new fraud patterns to Risk-Engine rule set
- Rule Tuning: Adjust thresholds based on false positive analysis
- Support Ticket Review: Analyze customer impact and compensation if needed
- Compliance Review: Ensure all regulatory reporting requirements are met

## 2.7 Owner

| Role                       | Responsibility                           | Escalation Contact          |
|----------------------------|------------------------------------------|-----------------------------|
| Primary: Security-Engineer | Lead incident response, rule adjustments | security-oncall@cargobit.eu |
| Secondary: On-Call Backend | System-level troubleshooting             | backend-oncall@cargobit.eu  |
| Tertiary: Compliance       | Regulatory oversight, reporting          | compliance@cargobit.eu      |

Table 5: Ownership Matrix for High-Risk Events

## 3. Scenario 2: Risk-Engine Down / Degraded

### 3.1 Detection

Alert Triggers:

- Grafana Alert: `rate(risk_engine_timeout_total[5m]) > 5`
- Gateway Latency: Significant increase in Security-Gateway response times
- Decision Breakdown: Unusual spike in "blocked" decisions (Fail-Safe behavior)
- Logs: `RISK_ENGINE_UNAVAILABLE` error entries

### 3.2 Immediate Actions (0-5 Minutes)

Gateway Fail-Safe Behavior:

When Risk-Engine is unavailable, the Security-Gateway automatically enters Fail-Safe mode. The default policy is to block all high-risk transactions to protect against potential fraud.

| Step | Action                            | Command/Check                                     |
|------|-----------------------------------|---------------------------------------------------|
| 1    | Confirm alert in Alertmanager     | Alertmanager UI / PagerDuty                       |
| 2    | Check Risk-Engine health endpoint | <code>GET localhost:3003/risk/health</code>       |
| 3    | Check system resources            | CPU, Memory, DB latency                           |
| 4    | Verify Circuit-Breaker status     | Gateway config: <code>circuit_breaker.open</code> |

Table 6: Immediate Actions - Risk-Engine Down

### 3.3 Triage (5-15 Minutes)

| Check        | Tool                                      | If Issue Found              |
|--------------|-------------------------------------------|-----------------------------|
| Pod Restarts | Kubernetes: <code>kubectl get pods</code> | Check crash logs, OOM kills |
| DB Latency   | DB monitoring dashboard                   | Escalate to DB-Team         |



|                    |                         |                           |
|--------------------|-------------------------|---------------------------|
| Queue Backlog      | Queue metrics dashboard | Scale consumers if needed |
| Recent Deployments | CI/CD pipeline history  | Identify breaking change  |
| Network Partition  | Network diagnostics     | Escalate to Platform-Team |

Table 7: Triage Checklist - Risk-Engine Down

## 3.4 Mitigation (15-60 Minutes)

### Option A: Risk-Engine Restart

- Initiate rolling restart of Risk-Engine pods
- Flush any stale cache entries
- Validate health-check endpoint returns 200 OK
- Monitor for 5 minutes before declaring recovery

### Option B: Rollback

- Identify last stable version from deployment history
- Deploy previous stable version via CI/CD pipeline
- Verify all pods are running the rolled-back version

### Option C: Gateway Temporary Mode

| Risk Level | Temporary Behavior     | Use When                             |
|------------|------------------------|--------------------------------------|
| GREEN      | Allow (no risk check)  | Only if absolutely certain, low risk |
| YELLOW     | Apply Delay mitigation | Default fallback mode                |
| RED        | Block                  | Always - safest option               |

Table 8: Gateway Temporary Mode Configuration

## 3.5 Recovery

| Indicator           | Target                          | Check Interval     |
|---------------------|---------------------------------|--------------------|
| Risk-Engine Latency | < 100ms p99                     | Every 30 seconds   |
| Error Rate          | < 0.1%                          | Every minute       |
| Circuit-Breaker     | Closed (normal operation)       | Gateway config     |
| Audit Events        | All events written successfully | Audit service logs |

Table 9: Recovery Indicators - Risk-Engine

## 3.6 Post-Incident (24-72 Hours)

- RCA Documentation: Root cause, timeline, and resolution steps
- Regression Tests: Add test case for the specific failure scenario
- Load Testing: Run load tests against Risk-Engine to verify stability under stress
- DB Index Optimization: If DB latency was a factor, review and optimize indexes
- Circuit-Breaker Tuning: Adjust thresholds if fail-safe triggered too early/late

## 3.7 Owner

| Role                                 | Responsibility                                 | Escalation Contact          |
|--------------------------------------|------------------------------------------------|-----------------------------|
| Primary: Backend-Team<br>Risk-Engine | Risk-Engine troubleshooting, restart, rollback | backend-risk@cargobit.eu    |
| Secondary: Platform-Team             | Infrastructure, Kubernetes, network            | platform-oncall@cargobit.eu |
| Tertiary: Security-Engineer          | Security policy oversight during degraded mode | security-oncall@cargobit.eu |

Table 10: Ownership Matrix - Risk-Engine Down

## 4. Scenario 3: Mitigation-Queue Overload

### 4.1 Detection

Alert Triggers:

- Grafana Alert: `mitigation_queue_lag_seconds > 5`
- Delay Mitigations: Delay actions executing later than scheduled
- 2FA Delays: Users reporting delayed 2FA verification codes
- Worker Metrics: High CPU usage on mitigation workers

### 4.2 Immediate Actions (0-5 Minutes)

| Step | Action                                   | Verification                       |
|------|------------------------------------------|------------------------------------|
| 1    | Confirm alert and check queue-lag metric | Current lag value, trend direction |
| 2    | Check worker count vs. queue depth       | Worker pool status                 |
| 3    | Check DB latency                         | DB query times, connection pool    |
| 4    | Check for blocked/stuck workers          | Worker process status              |

Table 11: Immediate Actions - Queue Overload

### 4.3 Triage (5-15 Minutes)

| Check              | Diagnostic                                 | If Issue Found                       |
|--------------------|--------------------------------------------|--------------------------------------|
| Active Mitigations | Count by type: Delay, 2FA, GPS, Logging    | Identify dominant type               |
| Worker Logs        | Error patterns, stuck processes            | Fix worker issue                     |
| Dead-Letter Queue  | Count of failed/undeliverable messages     | Clear or reprocess                   |
| Recent Deployments | Changes to mitigation service              | Rollback if needed                   |
| Yellow-Case Volume | Unusual spike in yellow-level transactions | May indicate Fraud-Wave (Scenario 1) |

Table 12: Triage Checklist - Queue Overload

## 4.4 Mitigation (15-60 Minutes)

### Option A: Scale Workers

Increase the number of mitigation worker instances to handle the queue backlog.

```
kubectll scale deployment mitigation-worker --replicas=10
```

### Option B: Enable Priority Mode

Reconfigure queue to prioritize critical mitigation types:

| Priority    | Mitigation Type       | Rationale                            |
|-------------|-----------------------|--------------------------------------|
| 1 (Highest) | 2FA Challenge         | User-blocking, time-sensitive        |
| 2           | GPS Verification      | Transaction completion depends on it |
| 3 (Lowest)  | Delay / Extra Logging | Can tolerate some lag                |

Table 13: Mitigation Priority Order

### Option C: Temporary Deactivation of Delay Mitigations

Only in extreme load situations: Temporarily disable Delay mitigations. Gateway will escalate YELLOW cases to require 2FA instead of Delay. This maintains security while reducing queue load.

### Option D: Queue Cleanup

- Clear Dead-Letter Queue of duplicate/failed events
- Remove duplicate mitigation requests (same transaction, same type)
- Reset stuck worker processes

## 4.5 Recovery

| Indicator         | Target                       | Verification            |
|-------------------|------------------------------|-------------------------|
| Queue Lag         | < 2 seconds                  | Queue metrics dashboard |
| Worker Stability  | No crashes, stable CPU < 70% | Worker metrics          |
| Delay Mitigations | Re-enabled and processing    | Configuration check     |
| Audit Events      | All mitigation events logged | Audit service           |

Table 14: Recovery Indicators - Queue Overload

## 4.6 Post-Incident (24-72 Hours)

- Autoscaling Review: Adjust HPA (Horizontal Pod Autoscaler) thresholds for workers
- Queue Monitoring: Add alerts for queue depth and lag trends
- Risk Rules Review: Investigate if rules generate too many YELLOW cases
- Capacity Planning: Ensure worker pool can handle peak loads + 50% buffer
- Dead-Letter Analysis: Identify root cause of failed messages

## 4.7 Owner

| Role                             | Responsibility                             | Escalation Contact          |
|----------------------------------|--------------------------------------------|-----------------------------|
| Primary: Mitigation-Service Team | Queue management, worker scaling           | mitigation-team@cargobit.eu |
| Secondary: Platform-Team         | Infrastructure scaling, Kubernetes         | platform-oncall@cargobit.eu |
| Tertiary: Security-Engineer      | Security impact of temporary deactivations | security-oncall@cargobit.eu |

Table 15: Ownership Matrix - Queue Overload

## 5. Owner Matrix & Escalation Paths

This section provides a consolidated view of ownership and escalation contacts for all incident types.

### 5.1 Consolidated Owner Matrix

| Scenario         | Primary                     | Secondary       | Tertiary          |
|------------------|-----------------------------|-----------------|-------------------|
| High-Risk Event  | Security-Engineer           | On-Call Backend | Compliance        |
| Risk-Engine Down | Backend-Team<br>Risk-Engine | Platform-Team   | Security-Engineer |
| Queue Overload   | Mitigation-Service Team     | Platform-Team   | Security-Engineer |

Table 16: Consolidated Owner Matrix

### 5.2 Escalation Timeline

| Time    | Action                                            | Contact              |
|---------|---------------------------------------------------|----------------------|
| T+0     | Alert triggered, On-Call notified                 | PagerDuty / Opsgenie |
| T+5min  | If no acknowledgment, escalate to Secondary       | Phone call + Slack   |
| T+15min | If unresolved, escalate to Tertiary + Manager     | All channels         |
| T+30min | If P1 still unresolved, invoke Incident Commander | Incident bridge      |
| T+60min | Executive notification for P1/P2                  | Email + Phone        |

Table 17: Escalation Timeline

## 6. Quick Reference Cards

Print these cards for quick reference during incidents. Each card summarizes the critical steps for one scenario.

### QUICK REFERENCE CARD 1: HIGH-RISK EVENT

| Phase     | Action                                                      | Time      |
|-----------|-------------------------------------------------------------|-----------|
| Detect    | Check: Grafana alert, block rate, support tickets           | 0-2 min   |
| Immediate | Confirm alert, check dashboard, activate Fraud-Mode         | 0-5 min   |
| Triage    | Scope: regional/global? Pattern? Rules? Engine health?      | 5-15 min  |
| Mitigate  | Block entities, Strict Mode, Geo-block, Notify stakeholders | 15-60 min |
| Recover   | Normalize metrics, disable Strict Mode, validate audit      | As needed |
| Post      | RCA, rule tuning, compliance review                         | 24-72h    |

### QUICK REFERENCE CARD 2: RISK-ENGINE DOWN

| Phase     | Action                                                     | Time      |
|-----------|------------------------------------------------------------|-----------|
| Detect    | Check: timeouts, latency, block rate spike, logs           | 0-2 min   |
| Immediate | Confirm, check health endpoint, resources, Circuit-Breaker | 0-5 min   |
| Triage    | Pods? DB? Queue? Deployment? Network?                      | 5-15 min  |
| Mitigate  | Restart / Rollback / Gateway Temporary Mode                | 15-60 min |
| Recover   | Latency < 100ms, errors < 0.1%, Circuit closed             | As needed |
| Post      | RCA, regression tests, load test, DB optimization          | 24-72h    |

## QUICK REFERENCE CARD 3: QUEUE OVERLOAD

| Phase     | Action                                                        | Time      |
|-----------|---------------------------------------------------------------|-----------|
| Detect    | Check: queue lag, delay execution, 2FA delays, worker CPU     | 0-2 min   |
| Immediate | Confirm alert, check lag, worker count, DB latency            | 0-5 min   |
| Triage    | Mitigation count by type, worker logs, DLQ, deployments       | 5-15 min  |
| Mitigate  | Scale workers / Priority mode / Disable Delay / Queue cleanup | 15-60 min |
| Recover   | Lag < 2s, workers stable, Delay re-enabled                    | As needed |
| Post      | Autoscaling, monitoring, rules review, capacity               | 24-72h    |

## KEY CONTACTS

| Team               | Email                          | Slack            |
|--------------------|--------------------------------|------------------|
| Security On-Call   | security-oncall@cargobit.eu    | #security-oncall |
| Backend On-Call    | backend-oncall@cargobit.eu     | #backend-oncall  |
| Platform On-Call   | platform-oncall@cargobit.eu    | #platform-oncall |
| Compliance         | compliance@cargobit.eu         | #compliance      |
| Incident Commander | incident-commander@cargobit.eu | #incidents       |

Table 18: Key Contacts Directory